

CONTROLLED DOCUMENT / INTERNAL

INCIDENT RESPONSE POLICY

Policy di risposta agli incidenti di sicurezza

Versione	1.0
Policy Owner	Chief Information Security Officer (CISO)
Approvata da	Board of Directors
Review Cycle	Annuale
Data di efficacia	24/08/2026

POLICY INTENT Stabilire un modello coerente, tempestivo e tracciabile per proteggere dati, sistemi, clienti e continuità operativa durante un incidente di sicurezza.

1. Purpose and Scope

La presente **Incident Response Policy** definisce i requisiti per l'identificazione, la segnalazione, la classificazione, l'escalation e la gestione degli incidenti di sicurezza che possono interessare **Finaxa**. L'obiettivo è garantire una risposta tempestiva, coordinata e documentata, limitando i potenziali impatti sui dati, sui sistemi, sui clienti, sulla continuità operativa e sulla conformità normativa dell'organizzazione.

La policy si applica a dipendenti, collaboratori, contractor, consulenti, fornitori e altri soggetti autorizzati. Il perimetro comprende sistemi **on-premise**, ambienti cloud, applicazioni SaaS, endpoint, reti, sistemi finanziari e di pagamento, informazioni aziendali e servizi gestiti da terze parti.

POLICY BOUNDARY La presente policy stabilisce principi, obblighi e responsabilità. Contatti operativi, SLA di escalation, playbook tecnici, modelli di comunicazione e checklist forensi sono definiti nell'Incident Response Plan e nelle procedure collegate.

2. Incident Classification

Gli incidenti devono essere classificati in base alla criticità dei sistemi e dei dati coinvolti, all'estensione dell'evento e al potenziale impatto operativo, finanziario, legale, regolamentare e reputazionale.

Severity	Criterio	Esempi	Escalation minima
CRITICAL	Impatto grave su dati, sistemi critici o continuità operativa	Ransomware esteso; data breach significativo; indisponibilità di un servizio finanziario critico	CISO; Executive Management; Legal; Compliance; Privacy
HIGH	Compromissione significativa ma circoscritta	Account privilegiato compromesso; accesso non autorizzato a dati Restricted	CISO; Security Team; System Owner
MEDIUM	Impatto limitato e controllabile	Malware contenuto; compromissione di un singolo account standard	Security Team; IT
LOW	Impatto minimo senza conseguenze rilevanti	Evento sospetto isolato o tentativo non riuscito	IT / Security

La classificazione deve essere rivalutata durante l'intero ciclo di gestione dell'incidente qualora emergano nuove evidenze o cambi l'impatto stimato.

Per gli eventi potenzialmente soggetti a **DORA**, la valutazione deve inoltre considerare, ove applicabile, clienti e transazioni interessati, durata e downtime, distribuzione geografica, perdita o compromissione dei dati, criticità dei servizi ed eventuale impatto economico.

3. Policy Statements

3.1 Incident Reporting

Tutti gli utenti devono segnalare tempestivamente eventi o attività sospette attraverso i canali di reporting approvati da Finaxa. Gli incidenti potenziali che coinvolgono sistemi, dati o servizi aziendali non devono essere ignorati o gestiti autonomamente. La segnalazione in buona fede non deve comportare conseguenze negative per il segnalante.

3.2 Identification and Triage

Il **Security Team** deve analizzare gli eventi segnalati, determinare se costituiscono un incidente di sicurezza, assegnare una severity e identificare i sistemi, i dati e i processi potenzialmente coinvolti. Devono essere stabiliti ownership, priorità e percorso di escalation.

3.3 Escalation

Gli incidenti classificati come High o Critical devono essere escalati tempestivamente al CISO e alle funzioni competenti. In base alla natura dell'incidente devono essere coinvolti IT, Risk Management, Legal, Privacy, Compliance, Business Continuity e i Business/System Owner interessati.

3.4 Containment, Eradication and Recovery

Gli incidenti confermati devono essere gestiti attraverso attività appropriate di **containment**, **eradication** e **recovery**, con l'obiettivo di limitare la propagazione e l'impatto dell'incidente, rimuoverne le cause e ripristinare in sicurezza sistemi e servizi. Le decisioni che comportano interruzioni rilevanti devono essere autorizzate secondo l'Incident Response Plan.

3.5 Evidence Preservation

Le evidenze rilevanti devono essere raccolte e conservate garantendone integrità e tracciabilità, in modo da supportare investigazioni interne, audit, analisi forensi ed eventuali esigenze legali o regolamentari. L'accesso alle evidenze deve essere limitato ai soggetti autorizzati e documentato attraverso una catena di custodia appropriata.

3.6 Personal Data Breach

Gli incidenti che coinvolgono dati personali devono essere sottoposti tempestivamente alle funzioni Privacy e Legal per determinare se costituiscono un **personal data breach** e valutare gli eventuali obblighi di notifica. Quando previsto dal GDPR, la notifica all'autorità di controllo deve avvenire senza ingiustificato ritardo e, ove possibile, entro **72 ore dal momento in cui Finaxa viene a conoscenza della violazione**. Devono inoltre essere valutati gli obblighi di comunicazione agli interessati e di documentazione della violazione.

3.7 Third-Party Incidents

Le terze parti devono notificare a Finaxa, senza ingiustificato ritardo, gli incidenti che possono compromettere dati, sistemi o servizi aziendali secondo i requisiti contrattuali applicabili. Tali incidenti devono essere valutati in funzione del loro potenziale impatto sull'organizzazione e gestiti con il coinvolgimento del Third-Party Owner.

3.8 Post-Incident Review

Gli incidenti significativi devono essere sottoposti a **post-incident review** per identificare **root cause**, control gap e remediation necessarie. Le azioni correttive devono avere owner, priorità e scadenze definite ed essere monitorate fino alla chiusura.

3.9 Communications

Le comunicazioni interne ed esterne relative a un incidente devono essere accurate, coerenti, autorizzate e limitate alle informazioni necessarie. Le comunicazioni a clienti, autorità, controparti, media e altri stakeholder devono essere coordinate con Legal, Privacy, Compliance e Corporate Communications, ove applicabile.

4. Incident Response Procedures

La gestione degli incidenti deve seguire un processo documentato composto dalle seguenti fasi:

IDENTIFICATION → TRIAGE → CONTAINMENT → ERADICATION → RECOVERY → REVIEW

4.1 Identification

Acquisire e registrare la segnalazione o l'alert; preservare le informazioni iniziali; identificare asset, utenti, dati, servizi e terze parti potenzialmente coinvolti.

4.2 Triage

Confermare o escludere l'incidente; determinare scope, severity e impatto preliminare; assegnare Incident Owner e attivare il percorso di escalation appropriato.

4.3 Containment

Applicare misure immediate e sostenibili per limitare la propagazione, bilanciando sicurezza, disponibilità dei servizi, preservazione delle evidenze e impatto sul business.

4.4 Eradication

Rimuovere malware, accessi persistenti e cause tecniche; correggere vulnerabilità e configurazioni; revocare o ripristinare credenziali compromesse; verificare l'efficacia delle azioni.

4.5 Recovery

Ripristinare sistemi e servizi da fonti affidabili, validare integrità e sicurezza, aumentare il monitoraggio e ottenere l'approvazione del Business/System Owner quando richiesta.

4.6 Post-Incident Review

Documentare timeline, impatto, root cause, decisioni, lessons learned e control gap; aprire e monitorare il remediation plan fino alla chiusura formale.

Il Security Team deve registrare gli incidenti nel sistema aziendale autorizzato, assegnare severity e ownership e coordinare le attività con le funzioni coinvolte. Le decisioni, le evidenze e le attività rilevanti devono essere documentate durante l'intero ciclo di gestione.

Il ripristino dei sistemi deve avvenire in modo controllato, verificando che la minaccia sia stata rimossa e che il servizio possa tornare operativo senza introdurre rischi non accettabili. Gli incidenti significativi devono generare, quando necessario, un **remediation plan** monitorato fino alla chiusura.

5. Roles and Responsibilities

La risposta agli incidenti richiede responsabilità definite e coordinamento tra funzioni tecniche, di controllo e di business.

Ruolo	Responsabilità
CISO	Owner della policy; supervisiona l'Incident Response, l'escalation degli incidenti significativi e il reporting al management body.
Security / Incident Response Team	Identifica, analizza, classifica e coordina la risposta; mantiene il registro, le evidenze e la timeline dell'incidente.
IT	Supporta containment, eradication, remediation e ripristino dei sistemi interessati.
Privacy / Legal / Compliance	Valuta gli impatti legali, regolamentari e contrattuali e gli eventuali obblighi di notifica o comunicazione.
Risk Management	Valuta l'impatto sul profilo di rischio e monitora rischi residui e remediation rilevanti.
Business / System Owner	Valuta l'impatto sui processi e servizi, supporta le decisioni di containment e approva il recovery quando previsto.
Business Continuity	Coordina, ove necessario, l'attivazione dei piani di continuità operativa e disaster recovery.
Utenti e terze parti	Segnalano tempestivamente eventi sospetti, preservano le informazioni disponibili e collaborano alle attività di risposta.

6. Exceptions Process

Qualsiasi eccezione ai requisiti della presente policy deve essere formalmente documentata, giustificata da una necessità aziendale e sottoposta a valutazione del rischio. La richiesta deve specificare il requisito interessato, il rischio associato, la durata dell'eccezione e gli eventuali **compensating controls**.

Le eccezioni devono essere approvate dal CISO o dall'autorità designata e avere una scadenza definita. Nessuna eccezione può eliminare o ritardare obblighi legali, regolamentari o contrattuali di notifica applicabili.

7. Compliance and Enforcement

Il rispetto della presente policy è obbligatorio per tutti i soggetti inclusi nel suo scope. La gestione degli incidenti deve essere coerente con i requisiti normativi, contrattuali e di sicurezza applicabili a Finaxa, inclusi, ove applicabili, **GDPR, UK GDPR, PCI DSS e DORA**.

La mancata segnalazione intenzionale di incidenti, l'ostacolo alle attività di investigazione o altre violazioni della policy possono comportare azioni disciplinari, limitazione degli accessi, escalation al management o azioni contrattuali nei confronti delle terze parti, nel rispetto della normativa e dei contratti applicabili.

8. Review and Maintenance

La presente policy deve essere revisionata almeno **annualmente** sotto la responsabilità del CISO e, quando necessario, a seguito di incidenti significativi, audit finding rilevanti, modifiche normative o cambiamenti sostanziali dell'ambiente tecnologico o del profilo di rischio.

Finaxa deve inoltre effettuare periodicamente test o simulazioni dell'**Incident Response Plan** per verificarne l'efficacia e identificare eventuali control gap. Gli esiti devono essere documentati e le azioni correttive monitorate. Gli aggiornamenti della policy devono essere registrati tramite controllo di versione.

9. Related Documents

La presente **Incident Response Policy** è subordinata alla **Information Security Policy** di Finaxa e deve essere applicata congiuntamente, ove pertinente, ai seguenti documenti:

- Access Control Policy
- Data Classification and Handling Policy
- Business Continuity and Disaster Recovery Policy
- Third-Party Risk Management Policy
- Incident Response Plan e relativi playbook
- Data Breach Notification Procedure

External Framework References

- [GDPR — Regolamento \(UE\) 2016/679, artt. 33–34](#)
- [DORA — Regolamento \(UE\) 2022/2554, artt. 17–20](#)
- [Regolamento delegato \(UE\) 2025/301 — tempistiche e contenuto del reporting ICT](#)
- [Regolamento di esecuzione \(UE\) 2025/302 — modelli e procedure di reporting ICT](#)
- [PCI DSS v4.x — Requirement 12.10, Incident Response](#)

GOVERNANCE NOTE I requisiti legali e regolamentari devono essere validati dalle funzioni Legal, Privacy e Compliance in base alla giurisdizione, al ruolo di Finaxa e alle caratteristiche specifiche dell'incidente.

Document Version History

Versione	Data	Descrizione	Owner
1.0	24/08/2026	Prima emissione	CISO